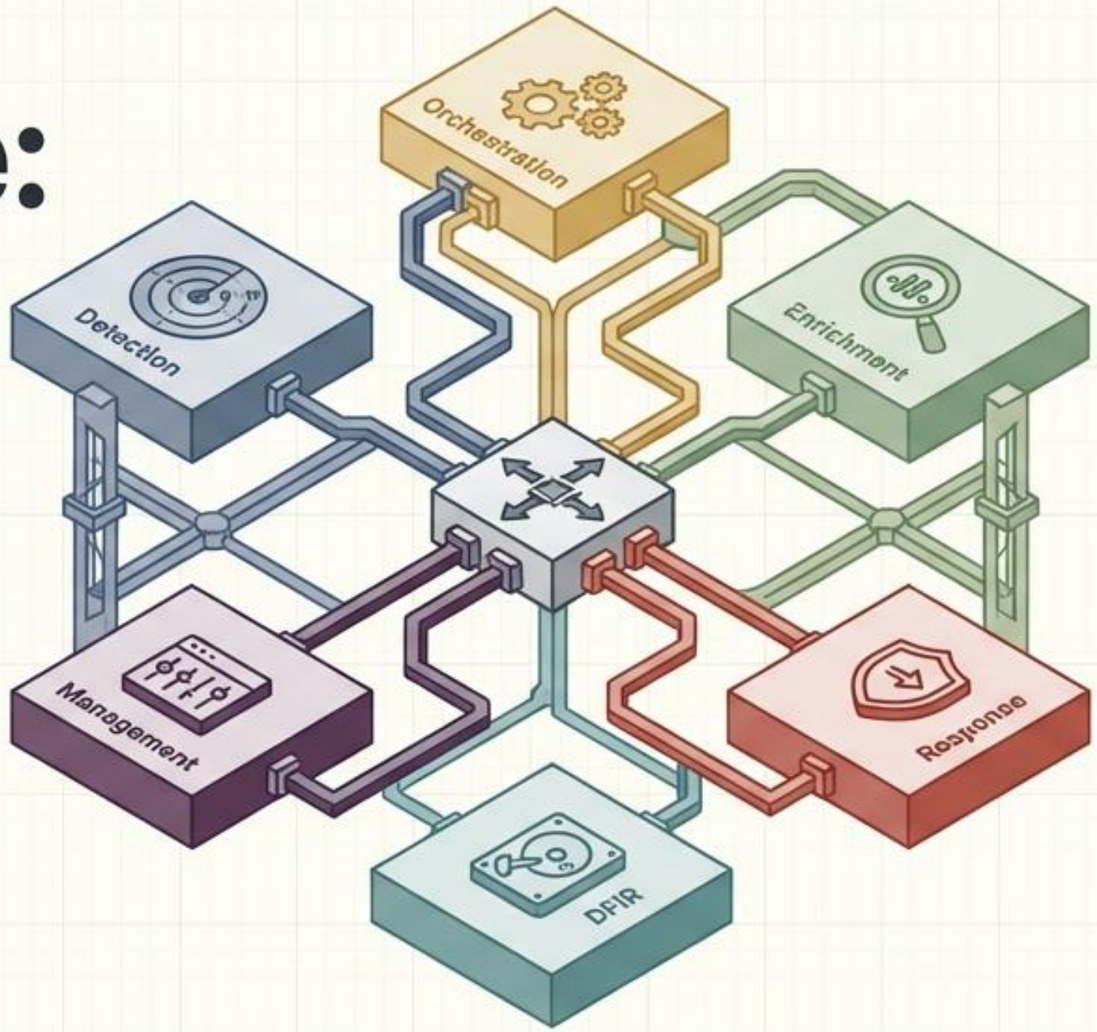
El SOC Invencible: Arquitectura y Orquestación Moderna

De herramientas aisladas a un Ecosistema de Respuesta Automatizado.

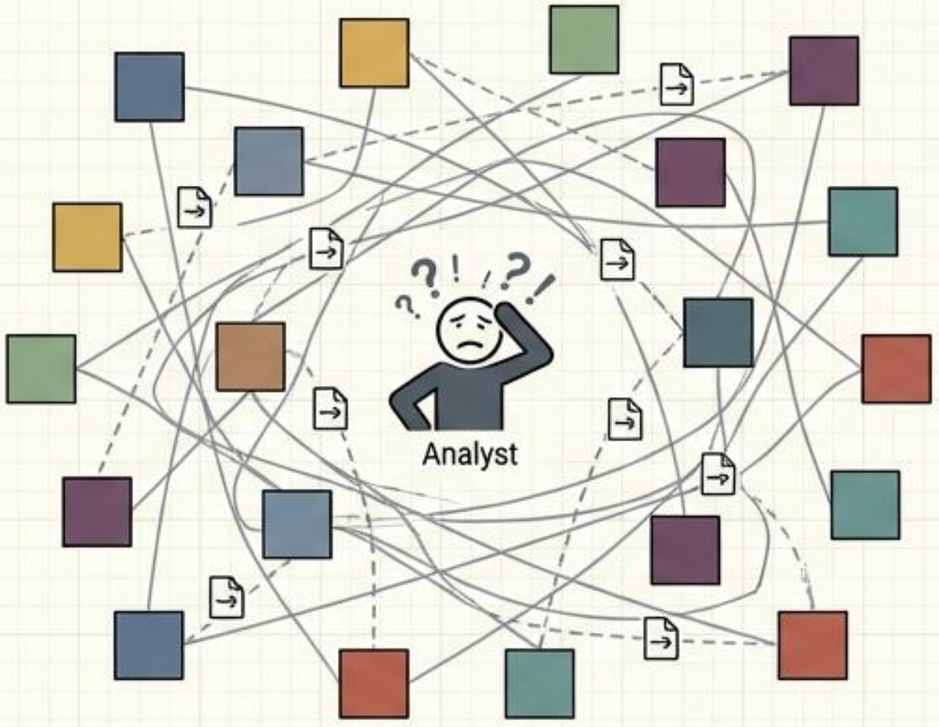


Diseño de Arquitectura de Seguridad Operativa

NotebookLM

El Paradigma: Silos vs. Ecosistema

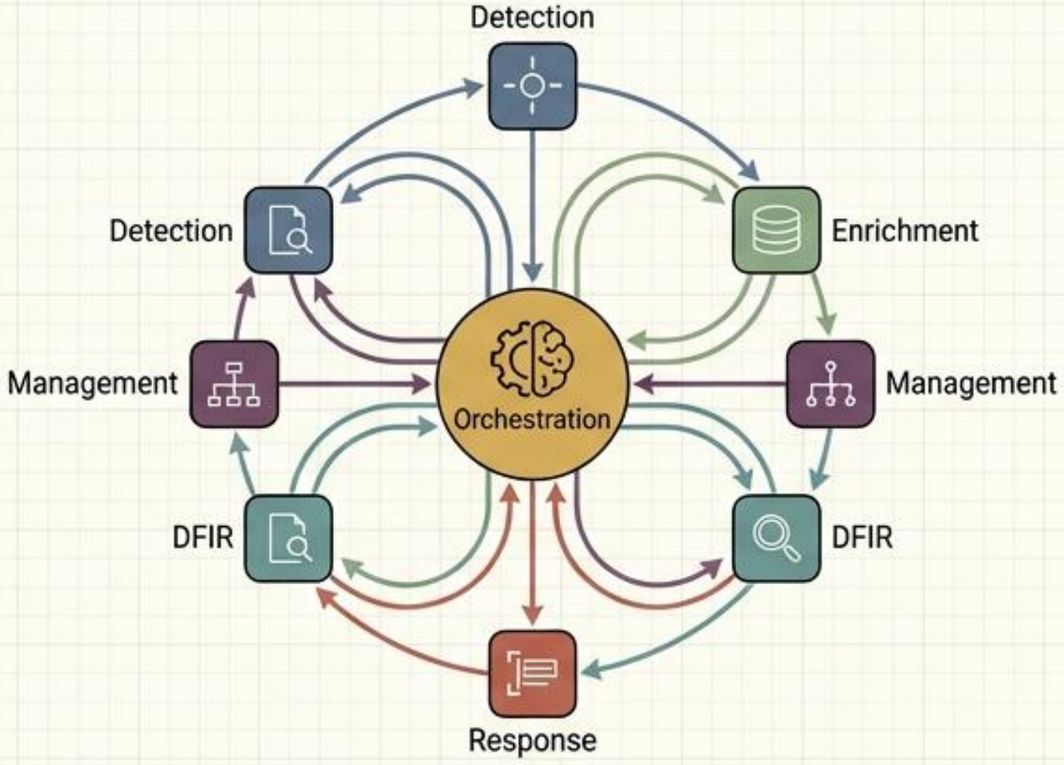
El Enfoque Tradicional



Tener grandes herramientas separadas es como un equipo de fútbol donde nadie se habla.

- **Fatiga de Alertas:** Miles de eventos irrelevantes.
- **Latencia (MTTR):** Tiempos de respuesta disparados por procesos manuales.
- **Errores y Falta de Contexto:** Analistas ciegos a investigaciones paralelas.

El Ecosistema de Respuesta



La integración transforma el software en una postura de defensa sólida.

- **Filtrado Automático:** Eliminación del ruido previo a la intervención.
- **Enriquecimiento:** Contexto táctico instantáneo.
- **Acción Coordinada:** Bloqueos en tiempo real.

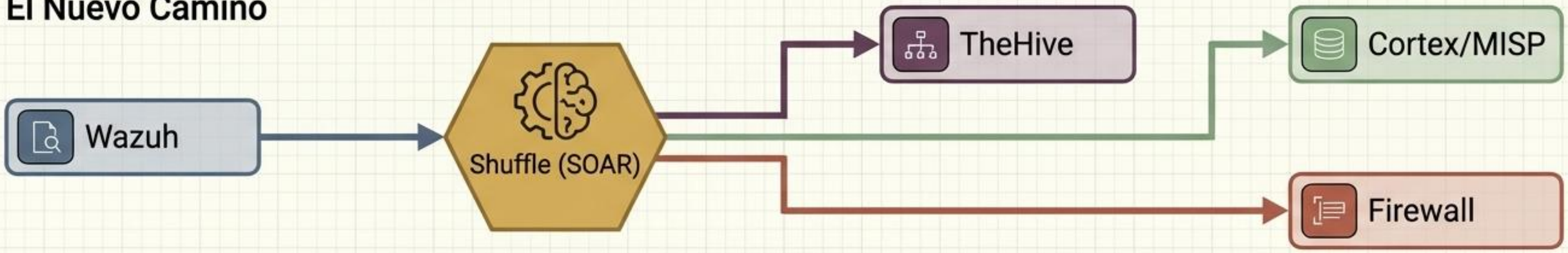
NotebookLM

El Error Arquitectónico Más Común

Enviar alertas directamente del sensor al gestor de casos arruina la operatividad. TheHive no es un repositorio de logs; es un **centro de expedientes**.

El Antiguo Camino

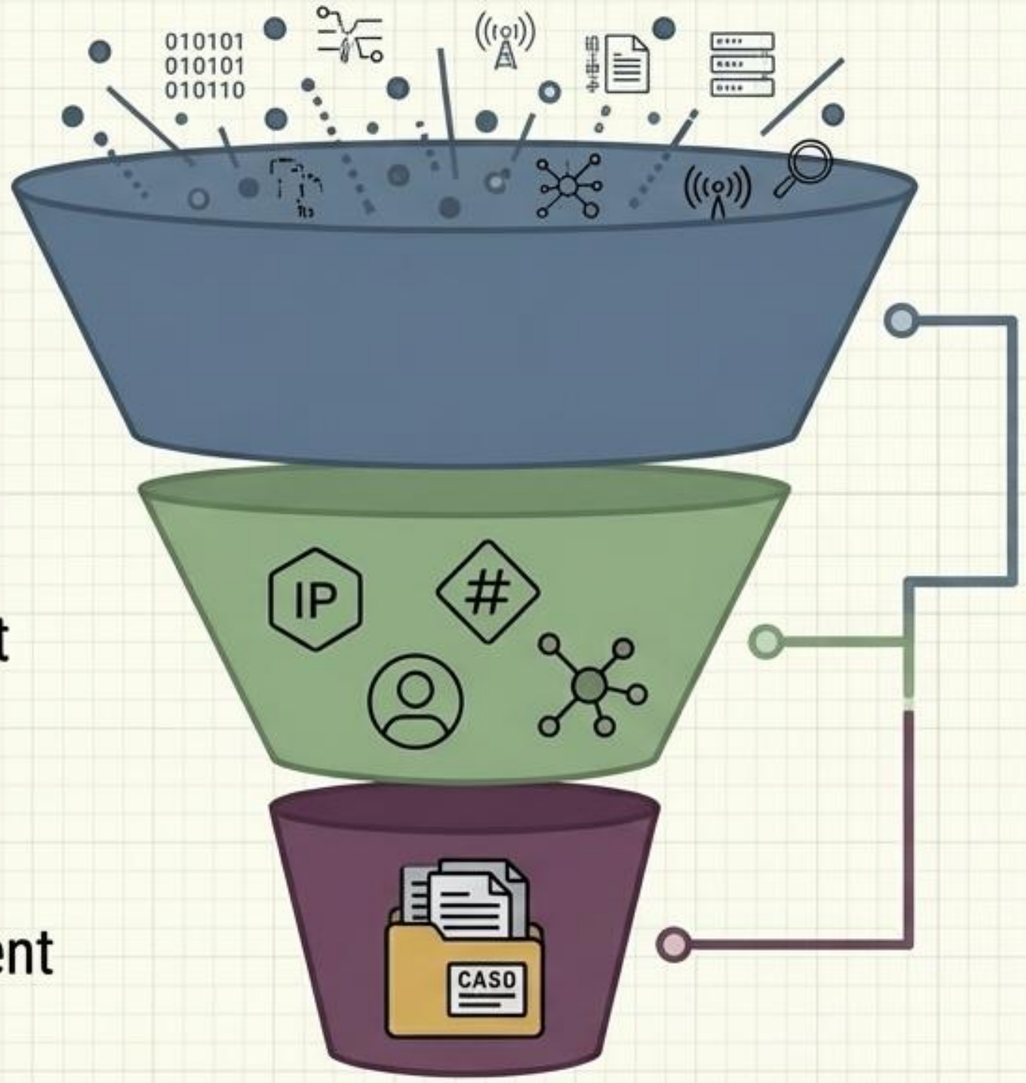
El Nuevo Camino



La Revolución del SOAR: Shuffle introduce filtrado, lógica de negocio y automatización antes de abrir un caso.

NotebookLM

La Taxonomía del SOC: Filtrando el Ruido



Detection

Enrichment

Management

ALERTA

Aviso técnico producido por una fuente (ej. regla de Wazuh por PowerShell sospechoso).

OBSERVABLE

Dato analizable extraído de la alerta (ej. IP remota, hash del script, usuario).

CASO

Contenedor de **investigación estructurado** en **TheHive**. Agrupa alertas, evidencias y tareas.

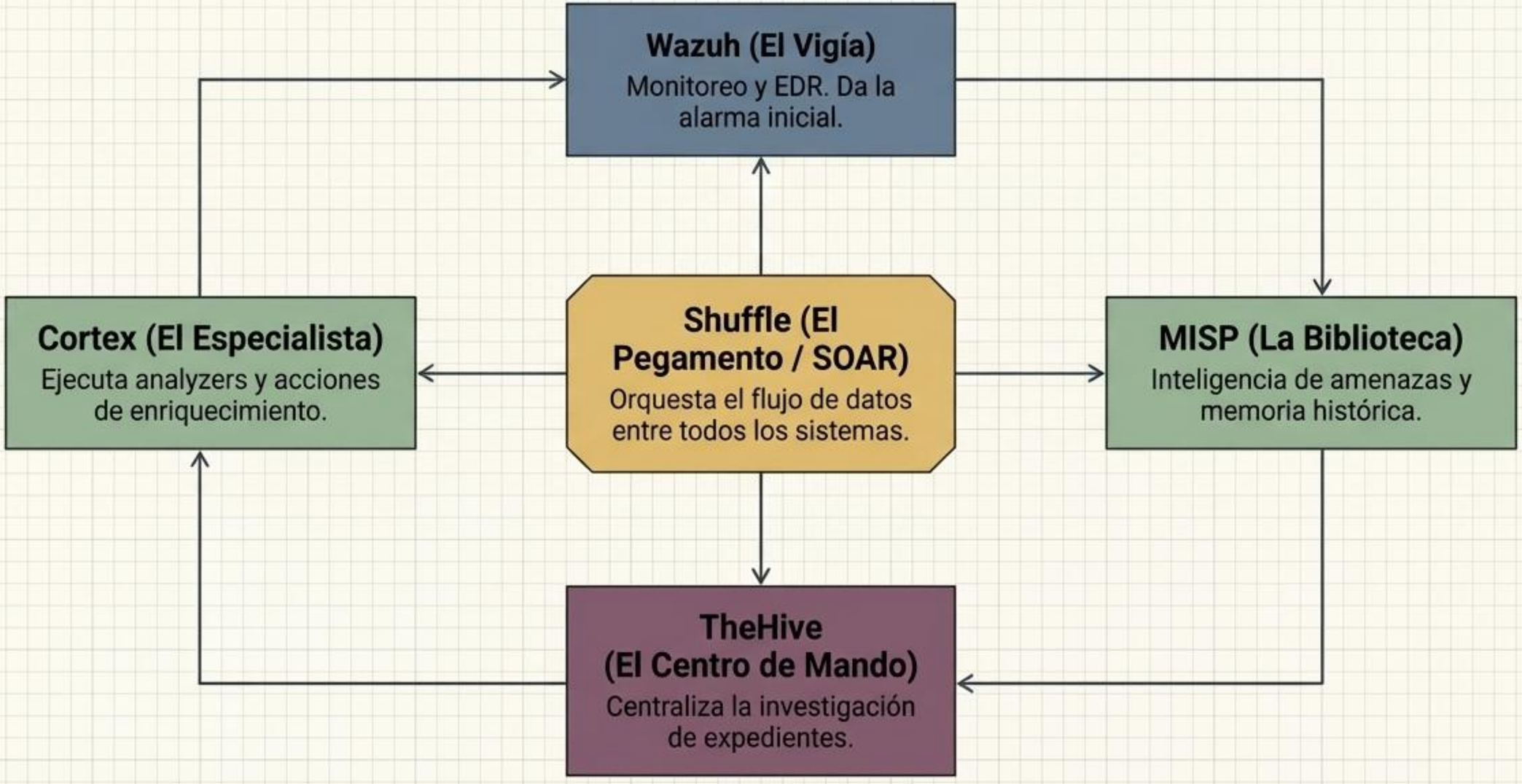
NotebookLM

La Orquesta: Capas Funcionales del Stack

Capa	Herramientas	Objetivo
Detección	Wazuh, Suricata, Zeek	Ver eventos y generar alertas
Orquestación	Shuffle	Automatizar decisiones y llamadas
Enriquecimiento	Cortex, MISP	Añadir contexto y reputación
Gestión	TheHive	Convertir alertas en casos investigables
DFIR/Hunting	Velociraptor	Investigar y recolectar evidencia
Respuesta	Firewalls, Active Response	Contener o bloquear

NotebookLM

Los Actores Principales: El Núcleo del SOC



NotebookLM

Complementos, no Rivales: Wazuh vs. Velociraptor

Wazuh (La Cámara de Seguridad)

- **Naturaleza:** Vigilancia 24/7.
- **Función:** Detecta anomalías, graba eventos continuos, avisa si alguien "salta la valla".
- **Enfoque:** Amplitud y monitoreo de telemetría constante.

Velociraptor (El Equipo CSI)

- **Naturaleza:** Cirujano Digital (DFIR) On-Demand.
- **Función:** Entra a la escena del crimen para recolectar RAM, registro y triage forense (VQL).
- **Enfoque:** Profundidad y caza de amenazas quirúrgica.

Shuffle actúa como puente para ejecutar el triage automáticamente tras una alerta crítica.

NotebookLM

Playbook 1: El Flujo Maestro (Fuerza Bruta SSH)

1. Sensor
Wazuh detecta fallos de autenticación seguidos de login exitoso.

→

2. Orquestador
Shuffle recibe alerta y extrae IP origen y usuario.

→

3. Enriquecimiento
Cortex consulta reputación; MISP busca coincidencias históricas.

→

4. Gestión
Si es maliciosa, se crea automáticamente un caso crítico en TheHive.

→

5. Respuesta
Shuffle ejecuta baneo temporal en Firewall (OPNsense).

→

6. Notificación
Alerta enviada a Slack/Telegram al equipo de guardia.

Tiempo total de ejecución: segundos.

NotebookLM

Playbook 2: Amenaza en el Endpoint (Malware)

1. Detección

Wazuh detecta la ejecución de un archivo o proceso sospechoso.

2. Orquestación

Shuffle recibe la alerta y extrae el hash del binario.

3. Análisis

Cortex consulta el hash contra motores de reputación. Devuelve estado malicioso.

4. DFIR Automático

Shuffle dispara a Velociraptor para recolectar un 'triage' forense del host infectado.

5. Expediente

La evidencia (procesos, autoruns) se adjunta al caso en TheHive instantáneamente.

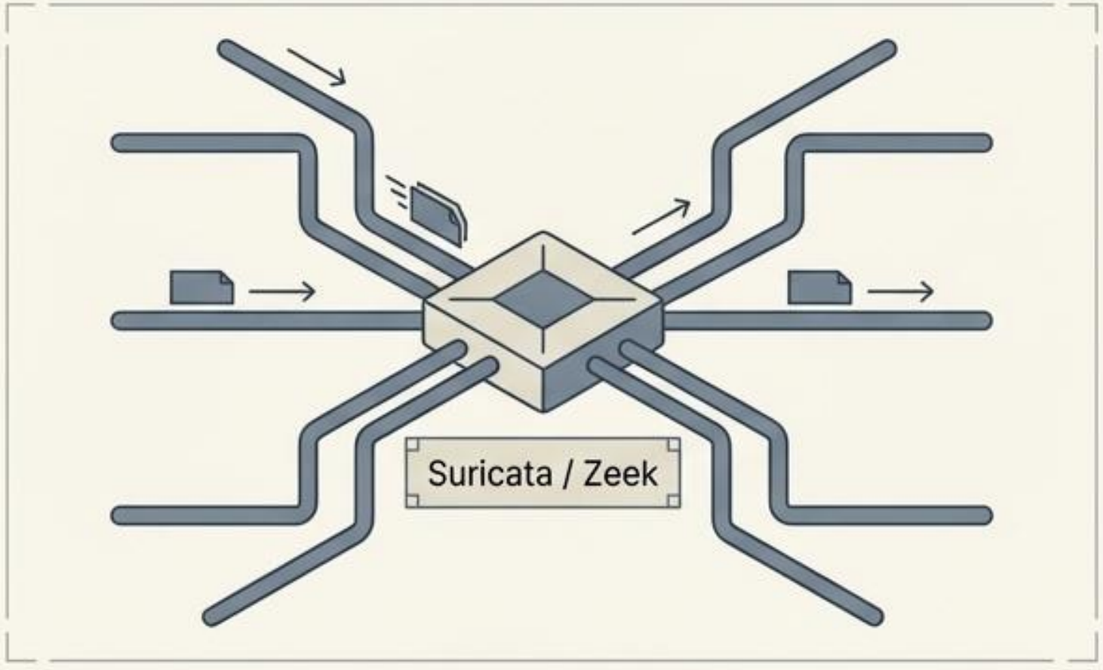
El analista obtiene el alcance real del impacto antes de tocar el teclado.

NotebookLM

Ampliando el Perímetro: Red y Vulnerabilidades

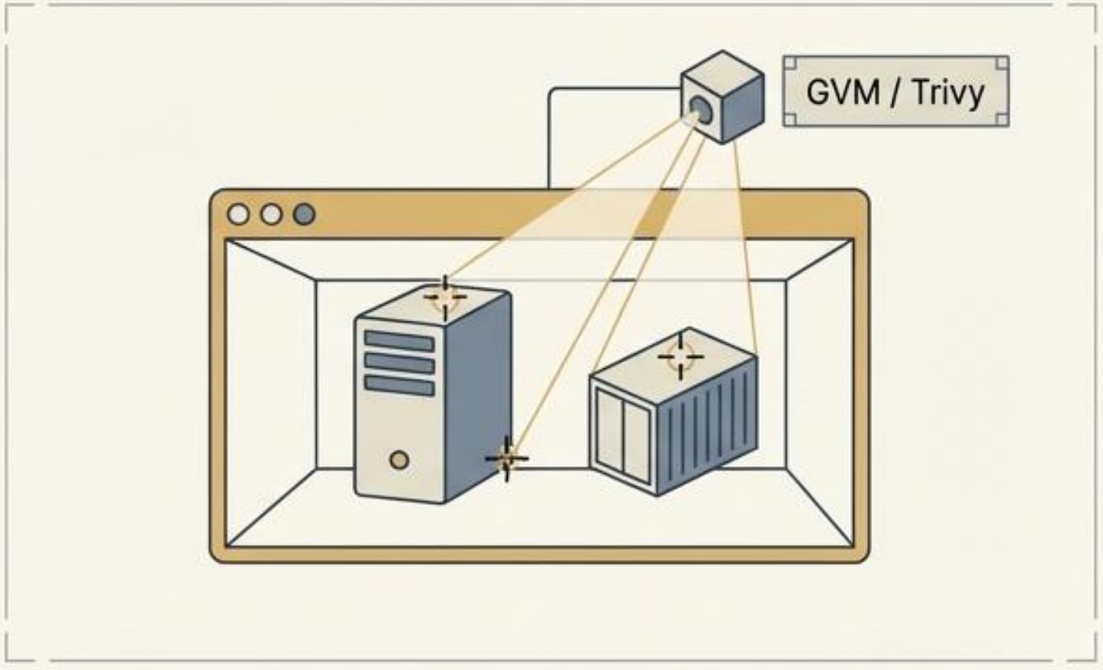
Wazuh cubre el endpoint, pero el ecosistema requiere visión externa y preventiva.

Visibilidad de Red - NTA/NDR



- **Herramientas:** Suricata (IDS) o Zeek (Comportamiento).
- **Por qué es necesario:** Atrapa escaneos de red, exfiltraciones HTTP/TLS y tráfico lateral que el sistema operativo no registra.

Gestión de Vulnerabilidades

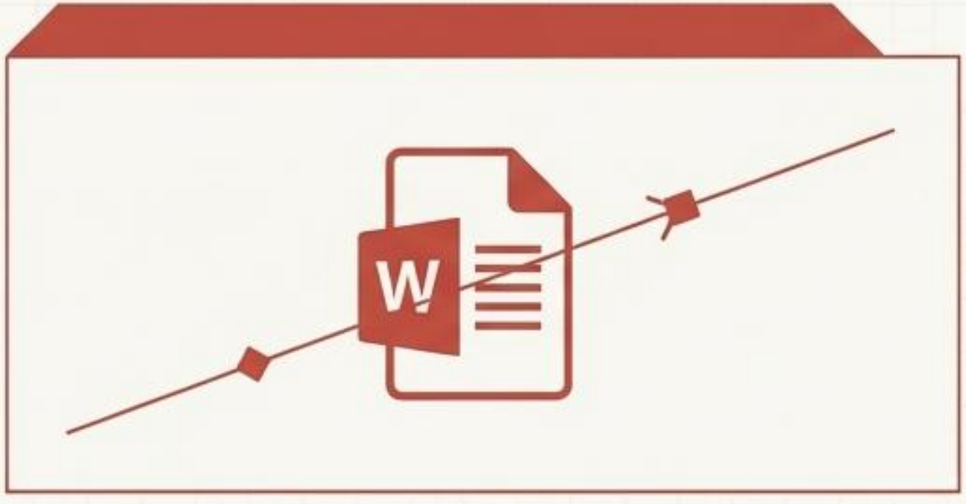


- **Herramientas:** GVM (OpenVAS para infraestructura) y Trivy (Contenedores).
- **Por qué es necesario:** Cierra las puertas (puertos expuestos, malas configuraciones) antes de que el atacante las encuentre.

NotebookLM

Seguridad Avanzada: Decepción e Inteligencia Táctica

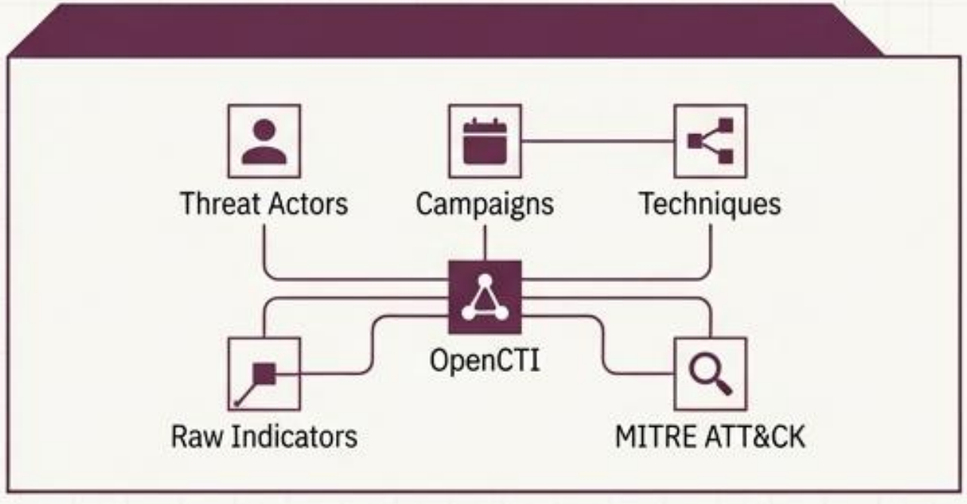
Decepción / Engaño



Canary Tokens & Honeypots

- **Concepto:** Trampas silenciosas (ej. un falso “Contraseñas.docx”).
- **Impacto:** Coste cero, probabilidad de falsos positivos casi nula. Si alguien lo toca, Shuffle abre un incidente crítico inmediato.

Inteligencia Avanzada



OpenCTI

- **Concepto:** Plataforma de Knowledge Management.
- **Impacto:** Eleva la madurez. Conecta indicadores crudos con actores de amenazas y tácticas del framework MITRE ATT&CK.

NotebookLM

Antipatrones Arquitectónicos: Lo que NO debes hacer

1. Abrir Demasiados Casos (Fatiga)

Enviar todo a TheHive destruye la confianza.
Solución: Definir umbrales estrictos en Shuffle (volumen + reputación) antes de crear un incidente.

2. Bloqueo Automático Prematuro

Aislar hosts ciegamente provoca apagones autoinfligidos.
Solución: Iniciar en modo semiautomático (enriquecer y notificar). Automatizar bloqueos más tarde.

3. No Normalizar Campos

Plataformas distintas hablan lenguajes distintos.
Solución: Usar Shuffle para mapear severidades y formatos para evitar corromper la ingesta de datos.

NotebookLM

La Hoja de Ruta: Despliegue por Fases

Validar cada capa con casos de uso antes de añadir complejidad

Fase 1 (MVP)

Wazuh + TheHive + Cortex + Shuffle. Detección base y orquestación.

Fase 2 (Inteligencia)

MISP. Memoria histórica y colaboración de IoCs.

Fase 3 (Profundidad)

Velociraptor.

Capacidad de DFIR y Threat Hunting.

Fase 4 (Red y Respuesta)

Suricata/Zeek + Bloqueo Firewall. Validación con Atomic Red Team.

Fase 5 (Madurez Total)

OpenCTI, Canary Tokens, Dashboards y Single Sign-On (SSO).

NotebookLM

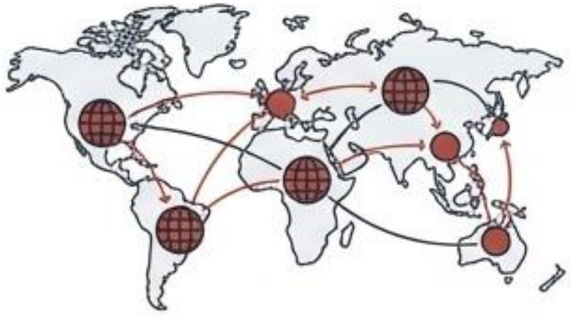
El **Ecosistema Profesional**: Acabados Críticos

1. Dashboards

Grafana / OpenSearch. Correlacionar subidas de bloqueos de firewall con alertas de Wazuh en un solo “Estado de Guerra” visual.

2. SSO & 2FA

Authelia / Keycloak. Un login único y seguro para los múltiples paneles del ecosistema. Evita el caos de credenciales.



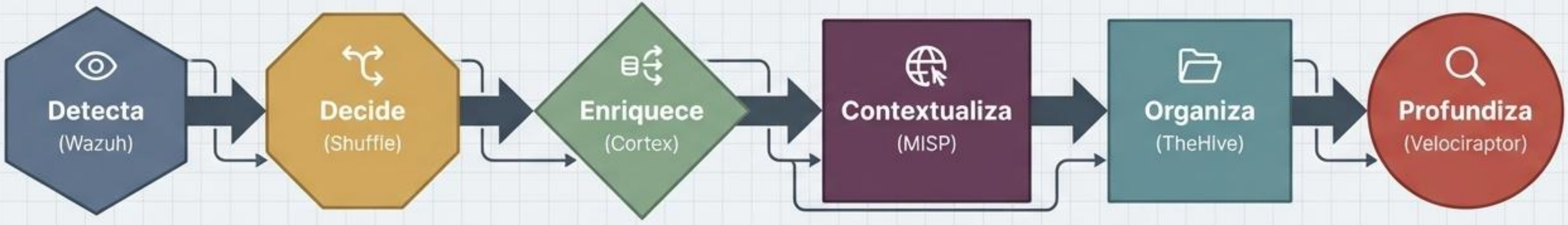
3. CrowdSec

Un ‘Waze’ para ciberseguridad. Bloquea IPs atacantes de forma colaborativa directamente en el firewall.

NotebookLM

Conclusión: El Valor Real de la Orquestación

La ventaja no está en coleccionar consolas, sino en el diseño inteligente de la lógica entre ellas.



Una arquitectura pequeña con playbooks afinados es invencible frente a un gigante sin orquestación.

NotebookLM